

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 17

Domain I - Information Security Governance

27 Questions	43 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 43 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM5-001)

Which statement BEST describes the role of information security governance within enterprise governance?

- A. It directs and oversees information security so that risk and resources support enterprise objectives.
- B. It independently defines business priorities for technology-dependent operations.
- C. It assigns every information-related risk decision to technical control operators.
- D. It replaces financial and operational governance when information assets are involved.

Question 2 (CISM5-002)

Scenario: A consumer products company gives brand teams wide authority to launch campaigns quickly. A new security process requires a central committee to approve every data use, causing teams to bypass review.

What should the information security manager recommend FIRST?

- A. Suspend all campaign launches until the central committee can review them.
- B. Define risk-based delegated authority, required safeguards, and escalation thresholds for brand teams.
- C. Transfer approval responsibility to external advertising agencies.
- D. Allow brand teams to use data without security accountability.

Question 3 (CISM5-003)

Scenario: A software publisher promises customers that critical vulnerabilities will be remediated within fixed timeframes. Product, support, and engineering teams interpret the commitment differently, and no executive owns performance.

What is the MOST significant governance weakness?

- A. The company has not purchased a new vulnerability scanner.
- B. The contractual obligation lacks consistent interpretation, accountable ownership, and enterprise oversight.
- C. Customers receive too much information about remediation.
- D. Engineering teams do not independently renegotiate customer contracts.

Question 4 (CISM5-004)

Which statement BEST defines accountability for an information security outcome?

- A. A designated owner is answerable for the outcome even when activities are delegated.
- B. Every participant is equally authorized to accept the associated risk.
- C. The person performing a task automatically owns the related business process.
- D. Accountability transfers to an auditor when the outcome is independently reviewed.

Question 5 (CISM5-005)

Scenario: A program office allows project managers to accept any information risk if treatment would delay delivery. Several accepted risks exceed the tolerance approved by the governing body.

What is the BEST corrective action?

- A. Allow project managers to raise the enterprise risk tolerance for their projects.
- B. Require the security manager to accept every project risk personally.
- C. Define acceptance limits and require risks beyond delegated authority to be escalated to authorized owners.
- D. Remove risk acceptance from project governance and leave it undocumented.

Question 6 (CISM5-006)

Scenario: A wholesale company is redesigning its supplier onboarding capability. Business architects are defining processes, information exchanges, applications, and external interfaces before selecting technology.

How should the information security manager participate?

- A. Identify information risks and security requirements while the target capability and architecture are being designed.
- B. Take ownership of the entire supplier onboarding process.
- C. Wait until implementation and then assess technical configurations.
- D. Require all existing supplier controls to remain unchanged.

Question 7 (CISM5-007)

What is the information security manager's PRIMARY role in enterprise architecture decisions?

- A. Replace enterprise architects when systems process sensitive information.
- B. Approve every detailed application design without business participation.
- C. Provide risk-based requirements and advice so architecture decisions support business and security objectives.
- D. Accept residual business risk for all architecture exceptions.

Question 8 (CISM5-008)

Scenario: A financial services group is selling a subsidiary but will provide shared technology services for eighteen months. Draft agreements do not clearly allocate incident reporting, access governance, or data deletion responsibilities during the transition.

What should the information security manager recommend before approval?

- A. Let operational teams determine responsibilities after the sale closes.
- B. Assign every responsibility to the buyer regardless of service control.
- C. Rely on existing informal practices throughout the transition.
- D. Define accountable parties, measurable obligations, escalation, assurance rights, and exit requirements.

Question 9 (CISM5-009)

Scenario: Application administrators provision access, certify that the access remains appropriate, and close their own review findings. Business managers receive no review results.

Which change would MOST improve governance?

- A. Allow administrators to approve access when requests are urgent.
- B. Require accountable business owners to certify access, with independent tracking of unresolved findings.
- C. Eliminate periodic certification and rely only on initial approval.
- D. Ask administrators to create more detailed self-certification records.

Question 10 (CISM5-010)

Scenario: A regional office wants to adopt an external collaboration service outside the approved architecture to satisfy a customer deadline. The service would create new information flows and support dependencies.

What should occur FIRST?

- A. The regional office should adopt the service because it owns the customer relationship.
- B. The security team should reject the service without considering business impact.
- C. The authorized architecture forum should review business need, information risk, dependencies, alternatives, and proposed treatment.
- D. The service provider should decide whether the enterprise can accept the risk.

Question 11 (CISM5-011)

What is the PRIMARY purpose of an information security roadmap?

- A. To record every operational security event
- B. To sequence initiatives, dependencies, resources, ownership, and timing needed to reach the desired state
- C. To replace the information security strategy with a project list
- D. To define detailed configurations for all security technologies

Question 12 (CISM5-012)

Scenario: A professional services firm adopts remote delivery as its primary operating model while clients increasingly require evidence of secure collaboration practices.

Why should the security strategy be reviewed?

- A. The operating model and client expectations may change critical assets, dependencies, obligations, and required capabilities.
- B. A strategy review is needed only when a security product reaches end of support.
- C. Client expectations automatically become law for every service.
- D. Remote delivery removes the need for enterprise security governance.

Question 13 (CISM5-013)

Scenario: A manufacturing group wants an accurate enterprise view of critical information assets. The current state consists of incomplete spreadsheets owned by separate plants, while the desired state requires accountable ownership and timely updates.

What should the information security manager do NEXT?

- A. Purchase an inventory platform before defining ownership and process requirements.
- B. Combine the existing spreadsheets without correcting governance gaps.
- C. Measure success only by the number of assets entered.
- D. Define the required ownership, process, information, and enabling technology capabilities, then prioritize the gaps.

Question 14 (CISM5-014)

Scenario: A technology startup has grown into a multinational enterprise through acquisitions. It uses an informal security model, and leaders want to adopt a comprehensive governance framework unchanged within six months.

What is the BEST recommendation?

- A. Implement every framework practice simultaneously to demonstrate commitment.
- B. Avoid frameworks because informal governance supported earlier growth.
- C. Select and phase practices based on objectives, obligations, risk, operating model, and current capability.
- D. Let each acquired company choose unrelated practices without enterprise mapping.

Question 15 (CISM5-015)

Scenario: A regional utility can fund either a foundational data classification initiative needed by several approved projects, a visually impressive dashboard, or replacement of a stable tool with minor efficiency benefits.

Which initiative should receive the HIGHEST priority?

- A. The dashboard because executives will see immediate output.
- B. The tool replacement because it is easiest to complete.
- C. An equal share for all initiatives even if none can reach a usable outcome.
- D. Data classification because it enables multiple strategic capabilities and improves risk-based decisions.

Question 16 (CISM5-016)

Scenario: The executive committee approved a three-year security strategy but declined to assign business owners or reserve staff for cross-functional initiatives. Progress has stalled despite adequate security-team funding.

What is the PRIMARY cause of the stalled execution?

- A. The security team has not purchased enough project management software.
- B. Executive approval was not converted into accountable ownership and enterprise resource commitments.
- C. The roadmap includes too many business outcomes.
- D. Cross-functional initiatives should be owned only by security engineers.

Question 17 (CISM5-017)

Scenario: A logistics company plans a shared customer platform. The security roadmap schedules separate long-term controls for legacy regional applications before the architecture team completes the migration sequence.

What should the information security manager recommend?

- A. Fund every regional control because the systems exist today.
- B. Stop protecting all legacy applications immediately.
- C. Coordinate security investments with migration dependencies, target capabilities, and necessary interim risk treatment.
- D. Exclude architecture information from security planning to preserve independence.

Question 18 (CISM5-018)

Scenario: A healthcare provider wants to reduce delays in revoking access for departing contractors. Its report shows only the number of termination tickets created.

Which measure would BEST demonstrate the intended outcome?

- A. The number of ticket categories available
- B. The monthly cost of the ticketing platform
- C. The number of administrators who can create tickets
- D. The percentage of contractor access revoked within the approved timeframe

Question 19 (CISM5-019)

Scenario: A publishing company is replacing separate editorial systems with a common content platform. Business units request major upgrades to controls embedded in applications scheduled for retirement within a year.

What is the BEST response?

- A. Approve every legacy upgrade because current applications always have priority.
- B. Fund proportionate interim protection and prioritize reusable controls required by the target platform.
- C. Remove all controls from retiring applications immediately.
- D. Let each business unit define an independent target architecture.

Question 20 (CISM5-020)

Scenario: A research consortium must establish continuous third-party monitoring within twelve months. Existing staff understand partner relationships but lack monitoring expertise, and the approved budget cannot support a fully internal team.

What should the information security manager do NEXT?

- A. Develop a blended plan for training, technology, external expertise, oversight, and knowledge transfer.
- B. Purchase tools and assume expertise will no longer be required.
- C. Outsource all risk ownership along with monitoring activities.
- D. Reduce the strategic objective to match current staff skills.

Question 21 (CISM5-021)

Which statement BEST describes the relationship among security policy, standards, and procedures?

- A. Procedures establish enterprise risk appetite, while policy records technical steps.
- B. Standards are optional suggestions that replace approved policy.
- C. Each document should be developed independently to preserve functional flexibility.
- D. Policy sets direction, standards define mandatory requirements, and procedures describe how activities are performed.

Question 22 (CISM5-022)

Scenario: A hospitality group is comparing an internal monitoring center, an external managed service, and a hybrid model. Options differ in coverage, expertise, data access, lifecycle cost, oversight, and exit flexibility.

How should the information security manager recommend a delivery model?

- A. Select the option with the lowest first-year price.
- B. Select internal delivery because security operations may never be sourced.
- C. Evaluate each option against required outcomes, risk, total cost, accountability, oversight, resilience, and exit needs.
- D. Allow the selected provider to determine acceptable enterprise risk.

Question 23 (CISM5-023)

Scenario: Regional executives initially supported a security strategy but now view it as a central technology program. They do not understand how their process changes contribute to customer trust and expansion goals.

What should the information security manager do?

- A. Connect each region's responsibilities and milestones to relevant business outcomes, risks, and benefits.
- B. Send additional technical configuration details without business context.
- C. Remove regional executives from governance meetings.
- D. Report only total enterprise spending to demonstrate commitment.

Question 24 (CISM5-024)

Scenario: A telecommunications company completes all planned awareness activities, but repeated measurements show no improvement in high-risk employee behaviors. Reports emphasize attendance and content volume.

What is the MOST appropriate conclusion?

- A. The assumptions, interventions, and measures should be reviewed because outputs are not producing the intended outcome.
- B. Behavior measures should be removed because they show unfavorable results.
- C. The same activities should continue indefinitely without review.
- D. The objective has been achieved because all activities were completed.

Question 25 (CISM5-025)

Scenario: An online payment provider has a very low appetite for prolonged transaction disruption but a greater appetite for delays in internal administrative reporting.

How should this difference affect the security strategy?

- A. Both areas should receive identical objectives and investment regardless of business impact.
- B. Risk appetite should be considered only after a disruption occurs.
- C. Resilience objectives and resources should reflect the lower appetite for transaction disruption.
- D. The security function should independently change enterprise risk appetite.

Question 26 (CISM5-026)

Scenario: A nonprofit wants to replace a fragmented identity environment. The initial proposal lists technical weaknesses but does not compare options or explain benefits to program delivery.

How should the proposal be improved?

- A. Add more technical terminology to demonstrate complexity.
- B. Describe business outcomes, risk reduction, alternatives, lifecycle costs, dependencies, and implementation impacts.
- C. State that all security modernization must be funded without comparison.
- D. Base the decision only on the age of the oldest system.

Question 27 (CISM5-027)

Scenario: A global manufacturer must exit a high-risk region and rapidly replace several critical service providers. The existing security strategy assumes stable suppliers, centralized processing, and a five-year architecture transition.

What should the information security manager do FIRST?

- A. Delegate enterprise security strategy to the new providers.
- B. Continue the existing roadmap to preserve consistency.
- C. Purchase replacement tools before evaluating changed business needs.
- D. Reassess strategic assumptions, dependencies, obligations, target architecture, capability gaps, and investment priorities.

Answer Key

Domain I - Information Security Governance

1 A	2 B	3 B	4 A	5 C
6 A	7 C	8 D	9 B	10 C
11 B	12 A	13 D	14 C	15 D
16 B	17 C	18 D	19 B	20 A
21 D	22 C	23 A	24 A	25 C
26 B	27 D			

Detailed Explanations

Question 1 (CISM5-001)

Correct answer: A - It directs and oversees information security so that risk and resources support enterprise objectives.

Information security governance provides direction and oversight so security risk, capabilities, and resources align with enterprise objectives. It does not independently set business priorities, transfer all risk authority to operators, or replace broader financial and operational governance.

Question 2 (CISM5-002)

Correct answer: B - Define risk-based delegated authority, required safeguards, and escalation thresholds for brand teams.

Risk-based delegation preserves the company's decentralized operating model while establishing accountability and escalation for higher-risk uses. A launch freeze is disproportionate, removing accountability creates unmanaged exposure, and agencies cannot assume the company's governance authority.

Question 3 (CISM5-003)

Correct answer: B - The contractual obligation lacks consistent interpretation, accountable ownership, and enterprise oversight.

A contractual commitment requires common interpretation, accountable ownership, and monitoring across the functions that fulfill it. A scanner does not establish governance, transparency is not the central issue, and engineers should not independently renegotiate enterprise obligations.

Question 4 (CISM5-004)

Correct answer: A - A designated owner is answerable for the outcome even when activities are delegated.

Accountability means a designated owner remains answerable for an outcome even when others perform supporting activities. Participation does not automatically confer risk authority or process ownership, and independent audit provides assurance without assuming management accountability.

Question 5 (CISM5-005)

Correct answer: C - Define acceptance limits and require risks beyond delegated authority to be escalated to authorized owners.

Documented acceptance limits and escalation ensure that decisions remain within delegated authority and approved tolerance. Project managers cannot change enterprise appetite, the security manager should not own every business risk, and undocumented acceptance eliminates accountability.

Question 6 (CISM5-006)

Correct answer: A - Identify information risks and security requirements while the target capability and architecture are being designed.

Early participation lets security requirements influence the capability, processes, information flows, applications, and interfaces. Waiting misses design decisions, security does not own the whole business process, and preserving every legacy control may obstruct the intended transformation.

Question 7 (CISM5-007)

Correct answer: C - Provide risk-based requirements and advice so architecture decisions support business and security objectives.

The security manager contributes risk analysis, requirements, and governance advice to business-aligned architecture decisions. Detailed designs require broader ownership, enterprise architects retain their role, and authorized business owners accept residual business risk.

Question 8 (CISM5-008)

Correct answer: D - Define accountable parties, measurable obligations, escalation, assurance rights, and exit requirements.

A transitional service arrangement needs explicit ownership, measurable duties, escalation, assurance, and exit provisions to govern shared dependencies. Post-closing decisions are too late, the buyer cannot own activities controlled by the seller, and informal practices provide insufficient accountability.

Question 9 (CISM5-009)

Correct answer: B - Require accountable business owners to certify access, with independent tracking of unresolved findings.

Business owners are positioned to judge continuing need, while independent tracking prevents administrators from closing their own findings without oversight. Urgency does not resolve conflicts, initial approval becomes stale, and more detailed self-review does not create segregation.

Question 10 (CISM5-010)

Correct answer: C - The authorized architecture forum should review business need, information risk, dependencies, alternatives, and proposed treatment.

An authorized architecture review enables a balanced decision based on business value, information risk, dependencies, alternatives, and treatment. Customer ownership does not confer exception authority, automatic rejection ignores legitimate needs, and providers cannot accept enterprise risk.

Question 11 (CISM5-011)

Correct answer: B - To sequence initiatives, dependencies, resources, ownership, and timing needed to reach the desired state

A roadmap translates strategic direction into sequenced initiatives with dependencies, resources, owners, and timing. Event records are operational, configurations belong in lower-level documentation, and a roadmap implements rather than replaces strategy.

Question 12 (CISM5-012)

Correct answer: A - The operating model and client expectations may change critical assets, dependencies, obligations, and required capabilities.

The internal operating-model shift and external client expectations can materially change dependencies, commitments, and capability needs. Reviews are not limited to technology lifecycle events, contracts are not automatically laws, and remote delivery increases rather than removes the need for governance.

Question 13 (CISM5-013)

Correct answer: D - Define the required ownership, process, information, and enabling technology capabilities, then prioritize the gaps.

The desired state requires coordinated governance, process, information quality, and supporting technology, so these capability gaps should drive initiatives. A tool-first approach may automate weak practices, consolidation alone preserves deficiencies, and asset counts do not demonstrate accuracy or ownership.

Question 14 (CISM5-014)

Correct answer: C - Select and phase practices based on objectives, obligations, risk, operating model, and current capability.

A phased, tailored approach uses the framework to address the enterprise's actual objectives, obligations, risks, and capability gaps. Wholesale adoption may overwhelm resources, past informal success does not meet current needs, and unrelated local practices weaken enterprise oversight.

Question 15 (CISM5-015)

Correct answer: D - Data classification because it enables multiple strategic capabilities and improves risk-based decisions.

The foundational classification capability creates broader strategic value and supports multiple risk decisions and dependent initiatives. Visibility and ease do not establish priority, while dividing inadequate funds can prevent any meaningful result.

Question 16 (CISM5-016)

Correct answer: B - Executive approval was not converted into accountable ownership and enterprise resource commitments.

Sponsorship must produce accountable owners, resources, and decisions across the enterprise, not merely formal approval. Project software cannot create commitment, business outcomes are central to alignment, and engineers cannot own changes belonging to business functions.

Question 17 (CISM5-017)

Correct answer: C - Coordinate security investments with migration dependencies, target capabilities, and necessary interim risk treatment.

Coordinating with the architecture roadmap avoids stranded investment while preserving proportionate protection during transition. Funding everything ignores system lifecycle, removing all protection creates exposure, and architecture information is essential to business-aligned security planning.

Question 18 (CISM5-018)

Correct answer: D - The percentage of contractor access revoked within the approved timeframe

Timely revocation directly measures whether the exposure from departing contractors is being reduced. Ticket categories, administrator counts, and platform cost are inputs or operational measures that do not demonstrate the desired risk outcome.

Question 19 (CISM5-019)

Correct answer: B - Fund proportionate interim protection and prioritize reusable controls required by the target platform.

The investment approach should manage material interim risk while building reusable target-state capabilities. Full legacy upgrades may become stranded cost, immediate control removal creates exposure, and independent target architectures conflict with the approved common platform.

Question 20 (CISM5-020)

Correct answer: A - Develop a blended plan for training, technology, external expertise, oversight, and knowledge transfer.

A blended capability plan can meet the objective within resource limits while preserving internal oversight and building sustainable knowledge. Lowering the objective may leave material need unmet, tools do not replace expertise, and external providers cannot own enterprise risk.

Question 21 (CISM5-021)

Correct answer: D - Policy sets direction, standards define mandatory requirements, and procedures describe how activities are performed.

Policy establishes management direction, standards translate it into mandatory requirements, and procedures explain execution. Procedures do not set risk appetite, standards are not merely optional, and independent development risks inconsistency across the hierarchy.

Question 22 (CISM5-022)

Correct answer: C - Evaluate each option against required outcomes, risk, total cost, accountability, oversight, resilience, and exit needs.

A strategic sourcing decision requires a balanced comparison of outcomes, risk, total cost, accountability, oversight, resilience, and exit capability. Initial price is incomplete, internal delivery is not universally required, and providers cannot define the enterprise's acceptable risk.

Question 23 (CISM5-023)

Correct answer: A - Connect each region's responsibilities and milestones to relevant business outcomes, risks, and benefits.

Stakeholder-specific communication makes responsibilities meaningful by linking them to business benefits, risks, and strategic milestones. Technical detail alone may reinforce the technology-only perception, excluding leaders weakens ownership, and spending does not demonstrate local value or outcomes.

Question 24 (CISM5-024)

Correct answer: A - The assumptions, interventions, and measures should be reviewed because outputs are not producing the intended outcome.

Completed activities are outputs, while unchanged high-risk behavior shows the desired outcome is not being achieved. Removing unfavorable measures hides effectiveness, and repeating the same approach without analysis is unlikely to improve results.

Question 25 (CISM5-025)

Correct answer: C - Resilience objectives and resources should reflect the lower appetite for transaction disruption.

Strategic objectives and resources should reflect the enterprise's differentiated willingness to accept risk, placing stronger resilience expectations on critical transactions. Equal treatment ignores business impact, appetite is prospective, and security advises but does not unilaterally set enterprise appetite.

Question 26 (CISM5-026)

Correct answer: B - Describe business outcomes, risk reduction, alternatives, lifecycle costs, dependencies, and implementation impacts.

A decision-ready business case explains enterprise outcomes, risk reduction, alternatives, total cost, dependencies, and transition effects. Technical complexity alone does not establish value, funding still requires governance, and system age is only one factor.

Question 27 (CISM5-027)

Correct answer: D - Reassess strategic assumptions, dependencies, obligations, target architecture, capability gaps, and investment priorities.

The regional exit and provider changes invalidate key strategic assumptions, so dependencies, obligations, architecture, capabilities, and priorities must be reassessed. Preserving the old roadmap creates misalignment, tool selection is premature, and providers cannot own the enterprise's security strategy.